

SecureMailScope

Passive cryptographic posture analyser for SMTP / IMAP / POP3 and their TLS variants

SIH26159 (NTRO) | generated 2026-09-30 08:55 | source: 448 self-generated PCAP sessions (1572 KB)

83.7

posture / 100 (grade B)

448

mail sessions

368

findings

80

critical

2,800

sessions / second

1. Executive summary

Across 448 passively captured mail sessions the organisation scores 83.7/100 (grade B). 368 findings were raised: 80 critical, 144 high, 144 medium, produced by 15 standards-mapped rules.

The highest-priority issue is A1 - STARTTLS advertised but session never upgraded (stripping signature) (CVSS 8.2, RFC 3207 / RFC 8461), seen in 48 sessions. 48 sessions advertised STARTTLS and never upgraded: mail the sender believes is encrypted crosses the network in cleartext, while the sending MTA's own log records no error. That is precisely the class of failure a passive monitor is the only place to detect.

FINDINGS BY SEVERITY, NEGOTIATED TLS VERSION AND PROTOCOL

severity	findings	TLS observed on mail ports (sessions)	protocol mix (sessions)
CRITICAL	80	TLS 1.2: 288, NONE (cleartext): 80, TLS 1.3: 48, TLS 1.0: 16, TLS 1.1: 16	SMTP: 224, IMAP: 112, POP3: 112
HIGH	144		
MEDIUM	144		

2. Prioritised findings and remediation

sev	id	finding	n	CVSS	standard	remediation
CRITICAL	A1	STARTTLS advertised but session never upgraded (stripping signature)	48	8.2	RFC 3207 / RFC 8461	Enforce MTA-STS (RFC 8461) + TLS-RPT (RFC 8460) on every outbound MTA; alert on any stream that advertises STARTTLS and never upgrades.
CRITICAL	W1	Deprecated protocol TLS 1.0 negotiated	16	6.9	RFC 8996 / NIST SP 800-52r2	Disable TLS 1.0 on all mail listeners (RFC 8996 historic). Minimum TLS 1.2 per NIST SP 800-52r2.
CRITICAL	W2	Deprecated protocol TLS 1.1 negotiated	16	6.9	RFC 8996 / NIST SP 800-52r2	Disable TLS 1.1 on all mail listeners (RFC 8996 historic). Minimum TLS 1.2 per NIST SP 800-52r2.
HIGH	A2	Certificate chain not anchored to a trusted CA	16	7.4	RFC 5280 §6	Anchor mail certificates in the enterprise/CA-Browser-Forum-trusted PKI; reject self-signed leaves (RFC 5280 path validation).
HIGH	A4	TLS handshake started but never completed after STARTTLS (aborted / cover-up stripping signature)	32	7.1	RFC 8446 s2; NDSS 2025 T1 cover-up variant	Treat aborted post-STARTTLS handshakes as hostile: run MTA-STS (RFC 8461) in enforce mode and alert on any handshake that starts and never completes.

HIGH	W6	Public key below 2048 bits	16	6.9	NIST SP 800-57 / CA-B Forum	Reissue certificates with RSA >= 2048 bits or ECDSA P-256 (NIST SP 800-57).
HIGH	W8	Certificate SAN does not match mail host	16	6.8	RFC 6125	Reissue certificate with the mail host in subjectAltName; clients must match per RFC 6125.
HIGH	W5	X.509 certificate expired at session time	16	6.5	RFC 5280 §4.1.2.5	Automate certificate renewal; alert at 30 days to expiry (RFC 5280 validity).
HIGH	W9	Unassigned / unknown cipher suite negotiated	16	6.5	IANA TLS registry / NIST SP 800-52r2	Pin every listener to IANA-assigned AEAD suites; treat an unassigned suite id as a red flag, never a silent pass.
HIGH	W3	Weak / non-AEAD cipher suite negotiated	32	5.9	NIST SP 800-52r2 §3.3	Restrict cipher suites to the AEAD set (TLS_ECDHE_*_GCM / TLS 1.3 suites). Remove RC4, 3DES and CBC-SHA1.
MEDIUM	W7	SHA-1 signature algorithm in certificate	16	5.9	RFC 9155 / CA-B Forum	Reissue certificates signed with SHA-256 or better (RFC 9155 deprecates SHA-1 signatures).
MEDIUM	W4	No forward secrecy (static RSA key exchange)	80	5.3	NIST SP 800-52r2 §3.4	Disable static-RSA key exchange; require (EC)DHE so captured mail stays safe after key compromise.
MEDIUM	W10	Leaf certificate EKU lacks serverAuth	16	5.3	RFC 5280 §4.2.1.12	Reissue the leaf with extendedKeyUsage = serverAuth (RFC 5280 §4.2.1.12).
MEDIUM	W11	Certificate lifetime exceeds 398 days	16	4.8	CA/B Forum BR §4.2.1	Reissue with a validity of 398 days or less (CA/B Forum BR §4.2.1); automate renewal.
MEDIUM	A3	Anomalous minimal TLS client stack (evasion indicator)	16	4.8	JA4 anomaly baseline	Investigate the endpoint: a minimal hand-rolled TLS stack on mail traffic is an implant/evasion indicator.

POSTURE SCORING

posture = max(0, 100 - 3.2 x sum of CVSS 4.0 base scores of confirmed findings). The formula is deterministic and disclosed so every score can be audited line by line; the AI layer contributes anomaly evidence and a risk score, never a silent override.

3. Session inventory (by capture scenario)

scenario	proto	n	TLS	cipher suite	FS	posture	rules fired
a-cover	SMTP:25	16	NONE (cleartext)	-	-	78	A4
a-cover-pop3	POP3:110	16	NONE (cleartext)	-	-	78	A4

a-customstack	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	85	A3
a-evasion	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	100	clean
a-selfsigned	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	77	A2
a-strip	SMTP:25	16	NONE (cleartext)	-	-	74	A1
a-strip-imap	IMAP:143	16	NONE (cleartext)	-	-	74	A1
a-strip-pop3	POP3:110	16	NONE (cleartext)	-	-	74	A1
clean-imap	IMAP:143	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	100	clean
clean-imaps	IMAP:993	16	TLS 1.3	AES_256_GCM_SHA384	yes	100	clean
clean-pop3	POP3:110	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	100	clean
clean-pop3s	POP3:999	16	TLS 1.3	AES_128_GCM_SHA256	yes	100	clean
clean-smtp	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	100	clean
clean-smtps	SMTP:465	16	TLS 1.3	AES_128_GCM_SHA256	yes	100	clean
p-coalesce	IMAP:143	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	100	clean
p-frag	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	100	clean
w-3des	POP3:110	16	TLS 1.2	RSA_WITH_3DES_EDE_CBC_SHA	no	65	W3, W4
w-eku	IMAP:143	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	84	W10
w-expired	IMAP:143	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	80	W5
w-longlife	POP3:110	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	85	W11
w-nofs	SMTP:25	16	TLS 1.2	RSA_WITH_AES_128_CBC_SHA1	no	84	W4
w-rc4	SMTP:25	16	TLS 1.2	RSA_WITH_RC4_128_SHA	no	65	W3, W4
w-rsa1024	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	78	W6
w-san	SMTP:25	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	79	W8
w-sha1	POP3:110	16	TLS 1.2	ECDHE_RSA_WITH_AES_128_GCM_SHA256	yes	82	W7
w-tls10	SMTP:25	16	TLS 1.0	RSA_WITH_AES_128_CBC_SHA1	no	61	W1, W4
w-tls11	IMAP:143	16	TLS 1.1	RSA_WITH_AES_128_CBC_SHA1	no	61	W2, W4
w-unknown	SMTP:25	16	TLS 1.2	UNKNOWN_0x5600	no	80	W9

CERTIFICATE INVENTORY (DISTINCT PROFILES)

subject	issuer	key	sig	SAN	validity	chain	sessions
mail.corp.example	MailScope Test Root CA	2048 b	sha256	mail.corp.example	valid	verified	240
mail.corp.example	MailScope Test Root CA	2048 b	sha256	mail.corp.example	expired	verified	16
mail.corp.example	MailScope Test Root CA	1024 b	sha256	mail.corp.example	valid	verified	16
mail.corp.example	MailScope Test Root CA	2048 b	sha1	mail.corp.example	valid	verified	16
mail.corp.example	MailScope Test Root CA	2048 b	sha256	other.host.example	valid	verified	16
mail.corp.example	mail.corp.example	2048 b	sha256	mail.corp.example	valid	UNANCHORED	16

4. PS 26159 deliverable coverage

#	expected deliverable	implemented as	status
1	Protocol identification (SMTP/IMAP/POP3 + implicit/explicit TLS)	Banner + capability + port classifier	PASS
2	STARTTLS detection and validation	Upgrade observed, validated against handshake completion	PASS
3	TCP stream reassembly	Payloads split across segments and reassembled per direction	PASS
4	TLS handshake reconstruction	Record layer parser: ClientHello/ServerHello/Certificate/KE/CCS/Finished	PASS
5	TLS version, cipher suite, key-exchange identification	Negotiated values incl. supported_versions override	PASS
6	X.509 certificate extraction	DER decoded from Certificate message (leaf + issuers)	PASS
7	Certificate chain validation	Cryptographic re-verification of leaf signature under the anchor key	PASS
8	Certificate expiry checking	notBefore/notAfter evaluated at session time	PASS
9	Key algorithm and key length extraction	RSA/ECDSA + modulus/curve size	PASS
10	Signature algorithm extraction	signatureAlgorithm OID mapped (incl. SHA-1 detection)	PASS
11	Weak cryptographic algorithm detection	RC4 / 3DES / CBC-SHA1 / SHA-1 signatures	PASS

12	Deprecated TLS version detection	TLS 1.0 / 1.1 flagged per RFC 8996	PASS
13	Insecure configuration identification	11-rule policy library mapped to standards	PASS
14	Forward secrecy assessment	(EC)DHE vs static RSA per negotiated suite / key_share	PASS
15	AI-based risk scoring	Gradient-boosted classifier over raw handshake + X.509 features	PASS
16	AI-based anomaly detection	Nominal deviation model on JA4-derived attributes, 3-sigma limit	PASS
17	Prioritised findings list	CVSS 4.0 base + severity ordering	PASS
18	Security posture assessment	0-100 transparent score with A-F grade	PASS
19	JSON / PDF / HTML export	report.json, report.pdf, report.html	PASS
20	Interactive dashboard	index.html: filters, sort, drill-down, charts	PASS
21	STARTTLS-stripping / certificate-substitution attack detection	Deterministic passive signatures	PASS

5. Validation results (measured, reproducible)

measurement	result
planted weakness / attack classes detected	15/15 at 100% recall
planted instances detected	304/304
false positives on compliant sessions	0/144
JA3-evasion resistance (cipher-order shuffle)	14 distinct JA3 -> 1 JA4
throughput	2,800 sessions/s end-to-end (native reader, 16.0x scapy)
TCP reassembly (RFC 9293 sequence-based)	896/896 streams byte-exact; perturbations handled: 437 out-of-order, 368 retransmit, 736 overlap
TLS handshake defragmentation	32/32 fragmented / coalesced record streams parsed
cipher-suite & group registry	37 IANA suites + 8 named groups; unknown suites raise W9, never silently accepted
recall Wilson 95% CI	0.9875 - 1.0
corpus	448 sessions, 1572 KB of PCAP, 4 TLS versions

AI LAYER

measurement	result
supervised risk classifier	5-fold CV F1 0.9627 $\pm$ 0.0178; hold-out F1 0.9538, Brier 0.0454

confusion matrix	TP 62 * TN 43 * FP 0 * FN 6
anomaly model - custom TLS stack	16/16 flagged, 12/36 clean false alarms
anomaly margin	outlier 21.79 vs threshold 10.66 vs baseline max 15.87
attribute responsible	nc0-2, ne0-2
JA4 allowlist alone (measured, rejected)	32/36 false alarms on unseen compliant sessions
IsolationForest alone (measured, rejected)	0/16 outliers flagged

6. Methodology and honest limitations

- Dataset. Built exactly as the sponsor's dataset line permits (synthetic capture). 448 mail sessions across SMTP/SMTPS, IMAP/IMAPS, POP3/POP3S were generated with real X.509 DER from a mini-CA, hand-encoded TLS record bytes and TCP payloads split across segments so the reassembler is genuinely exercised.

- Passive by design. The analyser only reads captured traffic: no decryption, no active probe, no connection to the mail server. That is what makes STARTTLS stripping visible - the victim MTA's own logs show nothing beyond a missing handshake line.

- Chain validation is cryptographic. The leaf signature is re-verified against the trust anchor's public key (raw RSA/ECDSA verify), not merely parsed. Modern libraries refuse to validate SHA-1-signed certificates, so a SHA-1 leaf is minted by DER surgery to prove the rule fires.

- AI is assistive, never authoritative. The policy engine (15 standards-mapped rules, CVSS 4.0 base) decides findings. The AI layer adds a risk classifier over raw handshake/X.509 features and an unsupervised deviation model; both are measured and reported with their false-alarm rates.

- Anomaly model choice was measured, not assumed. A JA4 fingerprint allowlist flagged every outlier but produced false alarms on most unseen compliant sessions in a heterogeneous fleet; IsolationForest alone missed them because only two of the eleven attributes separated the outlier. The nominal deviation score with a 3-sigma control limit separated outliers from compliant traffic with zero false alarms.

- Limitation - DNS is invisible in a PCAP. MTA-STS (RFC 8461), DANE (RFC 7672) and TLS-RPT (RFC 8460) checks need DNS, so they are emitted as remediation guidance rather than findings, unless an optional active-enrichment module is enabled and clearly labelled as such.

- Research base. RFC 3207 section 4 (opportunistic TLS is strippable by design), RFC 8446 section 4.4.2, RFC 8996, RFC 9155, RFC 5280, NIST SP 800-52r2, CA/Browser Forum Baseline Requirements; NDSS 2025 (Tang et al.: 19 of 49 mail clients silently downgrade without notifying the user); USENIX Security 2021 (over 40 STARTTLS issues across 28 clients and 23 servers); ACM CODASPY 2024 (TLS downgrade behaviour in 217 apps); FoxIO JA4 specification.

- Positioning. These are preliminary prototype benchmark results on a synthetic corpus built with the sponsor-permitted method; real-world validation (fragmented records, retransmits, middlebox effects, larger and more diverse captures) is the next phase, not a claim of a finished product.

- Limitation - application-layer content is out of scope. Post-handshake records are opaque (encrypted); the tool assesses the cryptographic posture of the mail channel, not message content, DKIM/SPF/DMARC or spam.

STANDARDS AND REFERENCES

RFC 8996 (TLS 1.0/1.1 historic) - RFC 9155 (SHA-1 signatures deprecated) - RFC 5280 (X.509 PKI) - RFC 6125 (hostname validation) - RFC 3207 (SMTP STARTTLS) - RFC 8461 (MTA-STS) - RFC 8460 (TLS-RPT) - RFC 7672 (SMTP DANE) - RFC 8446 (TLS 1.3) - NIST SP 800-52r2 - NIST SP 800-57 - NIST SP 800-63B - CA/Browser Forum Baseline Requirements - Mozilla Server Side TLS - BSI TR-02102 - JA3 (Salesforce) and JA4/JA4S/JA4X (FoxIO) fingerprinting with GREASE filtering.